Nomad-BlogStudio 코드 리뷰

> 리뷰 일자: 2026-10-12 / 대상 경로: D:₩WorkSpace₩platform₩Nomad-BlogStudio 주의: 폴더명은 "BlogStudio"이지만 실제 내용은 블로그 생성기가 아니라 **NOMAD Short Factory (ShortsOS)** 이다. package.json의 name 은 nomad-short-factory, CLAUDE.md/PRD.md 도 모두 숏폼/롱폼/음원 5-Track 플랫폼을 기술한다. 폴더명과 제품 정체성이 불일치하므로 정리가 필요하다.

1. 프로젝트 개요

- 한 줄 설명: 중국 드라마/상품 영상 소싱, AI 재생성 숏폼, 롱폼, Lofi 음원(Suno)까지 5개 트랙으로 콘텐츠를 대량 생산하고 YouTube/쿠팡파트너스/Distrokid 로 수익화하는 멀티테넌트 크레딧 과금 SaaS.
- 목적/대상 사용자: 한국 1인 크리에이터, 이커머스 운영자, 콘텐츠 에이전시 (PRD.md 1장).

구분	기술
프론트엔드	Next.js 16.2.9 (App Router), React 19.2, Tailwind v4, shadcn(base-ui), TanStack Query, Zustand, React Hook Form + zod, recharts, @xyflow/react
백엔드	Next.js Route Handlers (src/app/api/*), BullMQ 워커 (미가동)
DB/인증	Supabase (Postgres + RLS + Auth, @supabase/ssr)
인프라	Upstash Redis(예정), Supabase Storage, FFmpeg/yt-dlp 로컬 바이너리, Vercel 기본 템플릿
AI/외부 API	OpenAI(gpt-4o, TTS, Whisper), fal.ai Flux, ElevenLabs, DeepL, Suno, Coupang Partners, YouTube Data/Analytics, Toss Payments

- 현재 완성도 추정: **약 30%**
  - UI(대시보드 12개 메뉴, 페이지 23개)는 대부분 존재하고 `tsc --noEmit` 은 통과한다(오류 0).
  - 그러나 핵심 파이프라인이 연결되지 않았다. `lib/queue/bullmq.ts` 의 `add*Job` 함수와 워커 3종은 어디에서도 호출/기동되지 않고, `lib/ai/*`, `lib/media/*`, 대부분의 `lib/platforms/*` 는 app 코드에서 import 되지 않는 죽은 코드다(21개 lib 모듈 중 app 에서 사용되는 것은 fal-image, suno, youtube, landing/generator 4개뿐).
  - 트렌드 점수, 롱폼 스토리라인/스토리보드/점수, 분석 API 는 `Math.random()` 또는 하드코딩 목업을 반환한다.
  - 결제/크레딧/RLS 는 구현되어 있으나 치명적 결함이 있어 실사용 불가 수준이다.
- 핵심 기능 목록 (PRD 기준)
  - Track A/B/C 숏폼: 소싱 → 워터마크 제거 → STT → 번역 → TTS → 자막 → 인코딩 → 업로드
  - Track B 쿠팡파트너스 랜딩페이지 자동 생성 (`/landing/[slug]`)
  - Track D 롱폼: 주제 점수 → 스토리라인 → 10섹션 스토리보드 → 이미지 → Ken Burns → 인코딩
  - Track E Lofi 음원: Suno 생성 → Distrokid 배포
  - 크레딧 과금(Toss Payments), YouTube OAuth 채널 연동, 분석 대시보드, 자동화 플로우 캔버스

2. 구조 분석

경로	역할
`src/app/(auth)/`	로그인/회원가입 (클라이언트에서 Supabase Auth 직접 호출)
`src/app/(dashboard)/`	대시보드, 소싱, 작업, 트렌드, 롱폼, 음원, 배포, 랜딩, 분석, 자동화, 크레딧, 설정 페이지 (서버 컴포넌트에서 Supabase 직접 조회)
`src/app/(marketing)/page.tsx`, `src/app/page.tsx`	마케팅 랜딩
`src/app/landing/[slug]/page.tsx`	공개 쿠팡 랜딩페이지 (ISR 3600초)

경로	역할
src/app/api/*	18개 Route Handler: jobs, sourcing, trends, longform/, music, publish, landing, analytics, billing/, auth/youtube/, webhooks/
src/lib/supabase/	브라우저/서버/미들웨어용 Supabase 클라이언트
src/lib/billing/credits.ts	크레딧 단가표, consume/refund/runJobWithCredits
src/lib/queue/	BullMQ 큐 정의 + encode/publish/sourcing 워커 (미기동)
src/lib/ai/, src/lib/media/, src/lib/platforms/	외부 API 래퍼, FFmpeg/yt-dlp 래퍼 (대부분 미사용)
src/components/	도메인별 UI 컴포넌트 + shadcn ui
src/types/index.ts	도메인 타입 (157줄)
supabase/migrations/	001 스키마 + RLS, 002 RPC + RLS 재정의 + 인덱스
themes/shorts-factory.ts, taste-skill-shorts-factory.ts, skills/shorts-factory.json	디자인/트랙 정의. src 에서 import 되지 않음

데이터 흐름 요약: 사용자는 Supabase Auth 로 로그인하고, 미들웨어(src/lib/supabase/middleware.ts)가 대시보드 경로를 보호한다. 각 페이지/API 는 쿠키 기반 anon 키 클라이언트로 org_members 에서 org_id 를 조회한 뒤 RLS 하에 테이블을 읽고 쓴다. 작업 생성 API 는 runJobWithCredits 로 크레딧을 선차감하고 DB 에 queued 레코드를 넣지만, 실제 큐 투입은 주석("실제: BullMQ ... 추가")으로만 남아 있어 작업은 영원히 queued 상태로 남는다. 결제는 Toss 결제창 → /api/billing/confirm 에서 승인 후 크레딧 충전하는 구조다. 워커는 서비스 롤 키로 Supabase 에 접근하도록 작성되었지만, Next.js 서버리스와 분리된 워커 프로세스(엔트리포인트)가 없다.

3. 발견된 문제점

#	심각도	분류	위치(경로:줄)	내용
1	높음	보안	supabase/migrations/001_initial_schema.sql:286-287	org_members 에 for all using (user_id = auth.uid()) 정책. INSERT 시 WITH CHECK 가 USING 을 따르므로 임의 사용자가 자기 user_id 로 **아무 org_id 에나 멤버로 가입** 가능 → 테넌트 격리 붕괴
2	높음	보안	supabase/migrations/001_initial_schema.sql:226-234, 002_rpc_functions.sql:77	organizations / credit_transactions 에 멤버 UPDATE/ALL 허용 → 클라이언트 anon 키로 credit_balance, plan_id 직접 수정 및 거래내역 위조 가능
3	높음	보안	supabase/migrations/002_rpc_functions.sql:6-50	consume_credits, refund_credits 가 SECURITY DEFINER 이면서 p_org_id 를 인자로 받고 권한 검사가 없음. PostgREST 로 누구나 rpc/refund_credits 호출해 임의 조직에 무제한 크레딧 충전 가능 (EXECUTE 권한 revoke 없음)
4	높음	보안/버그	src/app/api/billing/confirm/route.ts:32-34	orderId nsf-{orgId}-{planId}-{ts} 를 - 로 split. orgId(UUID)에 하이픈이 있어 parts[1]은 UUID 첫 조각, planId 는 항상 무효 → 결제 승인 후 크레딧 미지급. 또한 결제 금액이 플랜가와 일치하는지 검증하지 않고, orderId 저장/중복 처리도 없음
5	높음	보안	src/app/api/billing/checkout/route.ts:10-31	orgId 를 요청 본문에서 받아 사용자 소속 확인 없이 주문에 포함. 금액은 클라이언트로 전달되어 결제창에서 변조 가능
6	높음	보안	src/app/api/webhooks/toss/route.ts:8-35, src/app/api/webhooks/make/route.ts:4-33	웹훅 서명/시크릿 검증 없음(주석으로 "생략" 명시). make 웹훅은 임의 jobId 를 done 처리하고 임의 org 에 환불 트랜잭션 삽입 시도

#	심각도	분류	위치(경로:줄)	내용
7	높음	버그	src/lib/billing/credits.ts:53-56	refund() 가 update({ credit_balance: supabase.rpc('increment', ...) }) 로 PromiseBuilder 객체를 값으로 넣음 → 잔액 복구 불가. increment(x) 함수 자체도 x + 1 반환(002:31-33)으로 의미 오류
8	높음	버그	src/lib/billing/credits.ts:22-41, 59-73	consume 이 RPC 오류를 무시하고, 잔액 확인-차감이 분리되어 경쟁 조건 존재. task 내부 Supabase 오류는 throw 되지 않으므로 insert 실패해도 차감만 되고 환불 없음
9	높음	버그	src/app/(auth)/signup/page.tsx:21-25, supabase/migrations/001 전체	가입 시 org_name 을 메타데이터로만 보내고 조직/멤버 생성 트리거·API 가 없음 → 신규 사용자는 org 가 없어 모든 API 가 org_id = undefined 로 동작
10	높음	버그	src/lib/supabase/middleware.ts:32	/landing 접두사를 대시보드로 판정 → 공개 쿠팡 랜딩 /landing/[slug] 도 비로그인 시 /login 으로 리다이렉트되어 제휴 수익 경로 차단
11	중간	보안	src/app/api/auth/youtube/callback/route.ts:20, 54-63	OAuth state 가 서명 없는 base64 JSON(CSRF 방어 없음), orgId 를 state 에서 신뢰. 토큰을 access_token_enc 컬럼에 **평문 저장**
12	중간	보안	src/app/api/publish/route.ts:11-20, 34-46, src/app/api/landing/route.ts:11, 30	orgId 를 쿼리/본문에서 받음. RLS 로 일부 보호되나 #1 결함과 결합 시 타 조직 데이터 접근 가능. 크레딧 차감도 클라이언트 지정 org 에 대해 수행
13	중간	버그	src/app/api/publish/route.ts:85, supabase/migrations/001_initial_schema.sql:181	status 에 'scheduled'/'published' 삽입하지만 CHECK 제약은 ('pending','uploading','done','failed') → 업로드 기록 항상 실패
14	중간	버그	src/lib/queue/workers/encode.worker.ts:6, 124	워커에서 refund() 사용 → next/headers cookies() 기반 클라이언트라 요청 컨텍스트 밖에서 예외. 또한 encode 큐의 Track D 는 jobs.track CHECK('A','B','C')와 불일치
15	중간	구조	src/lib/queue/bullmq.ts:63-96, src/app/api/jobs/route.ts:69, src/app/api/sourcing/route.ts:66	큐 투입 함수가 한 번도 호출되지 않고 워커 엔트리포인트 없음 → 작업이 영원히 queued. 크레딧만 차감됨
16	중간	품질	src/app/api/trends/route.ts:40-41, src/app/api/longform/score/route.ts:13, src/app/api/longform/storyline/route.ts:20, src/app/api/analytics/route.ts:40-52	점수/스토리라인/분석을 랜덤값·하드코딩 목업으로 반환. lib/ai/openai-chat.ts 의 실제 구현은 미사용
17	중간	버그	src/lib/ai/fal-image.ts:12-14, 37	API 키 없음/오류 시 placeholder URL 반환 → 예외가 없어 크레딧이 환불되지 않고 과금됨 (src/app/api/longform/image/route.ts:24)
18	중간	설정	.env.local, .env / src 전체 process.env	코드가 쓰는 SUPABASE_SERVICE_ROLE_KEY, NEXT_PUBLIC_APP_URL, GOOGLE_CLIENT_ID, UPSTASH_REDIS_*, TOSS_* 등이 env 에 없고, env 에는 다른 프로젝트(FastAPI/Celery)용 SUPABASE_SERVICE_KEY, ANTHROPIC_API_KEY, CELERY_BROKER_URL 등이 들어 있음. 실 키가 평문 파일로 존재(.gitignore 의 .env* 로 커밋은 차단됨)
19	중간	보안	src/lib/media/ytdlp.ts:29-31	사용자 URL 을 -- 구분자 없이 yt-dlp 인자로 전달 → --exec 등 옵션 주입 가능(현재는 미사용 코드지만 연결 시 위험)

#	심각도	분류	위치(경로:줄)	내용
20	중간	성능	src/app/api/longform/image/route.ts:29-42	sections JSON 전체를 읽고 다시 쓰는 read-modify-write. 동시 이미지 생성 시 섹션 덮어쓰기 경쟁
21	낮음	구조	src/app/api/, src/app/(dashboard)/ (약 20곳)	org_members 에서 org_id 조회하는 동일 블록이 반복. .single() 이라 다중 조직 사용자에서 오류
22	낮음	구조	supabase/migrations/002_rpc_functions.sql:56-126	001 의 RLS enable/정책/인덱스를 중복 정의(이름만 다른 동일 인덱스 jobs(org_id,status) 등 2벌 생성)
23	낮음	품질	src/app/(dashboard)/*.tsx (18곳)	any 사용 18건, Supabase 생성 타입 미사용. src/types/index.ts 와 DB 스키마가 수동 동기화
24	낮음	품질	src 전체 (242회), themes/shorts-factory.ts, taste-skill-shorts-factory.ts	색상 hex 하드코딩 242회. 테마 파일 2벌이 서로 다르고 어디서도 import 되지 않음
25	낮음	품질	src/app/api/longform/[id]/encode/route.ts:24-28	크레딧 차감 후 100ms sleep 만 하고 가짜 jobId 반환
26	낮음	설정	README.md, package.json:2	README 는 create-next-app 기본값, test 스크립트/테스트 없음. 폴더명과 패키지명 불일치

심각도 높음 상세

1. **org_members 자가 가입 (#1)**: self_access 정책이 for all 이고 WITH CHECK 가 없어서 USING 식이 INSERT 검사에도 적용된다. 로그인한 아무 사용자가 브라우저 콘솔에서 supabase.from('org_members').insert({ org_id: <타 조직>, user_id: <내 id>, role: 'super_admin' }) 을 실행하면 my_org_ids() 에 타 조직이 포함되어 모든 데이터와 크레딧이 노출된다. 멀티테넌트 SaaS 로서 가장 치명적인 결함이다.
2. **크레딧/플랜 직접 수정 (#2)**: organizations 의 UPDATE 와 credit_transactions 의 ALL 이 멤버에게 열려 있어 결제 없이 credit_balance 와 plan_id 를 원하는 값으로 바꿀 수 있다. 잔액·플랜 컬럼은 서버(서비스 롤 또는 SECURITY DEFINER 함수)만 수정 가능해야 한다.
3. **공개 RPC 로 크레딧 발행 (#3)**: Supabase 는 public 스키마 함수의 EXECUTE 권한을 anon/authenticated 에게 기본 부여한다. refund_credits 는 소속 검사 없이 잔액을 증가시키므로 비로그인 사용자도 REST 로 임의 조직에 크레딧을 충전할 수 있다. revoke execute ... from anon, authenticated 및 함수 내부 auth.uid() 검사가 필요하다.
4. **결제 승인 로직 파손 (#4, #5)**: UUID 하이픈 때문에 orderId 파싱이 항상 실패해 정상 결제 고객에게 크레딧이 지급되지 않는다. 동시에 금액-플랜 일치 검증, 주문 사전 저장, 멱등 처리, orgId 소속 검증이 모두 없어 수정 후에도 저가 결제로 상위 플랜 충전, 새로고침 재충전이 가능해진다. 주문 테이블 기반으로 재설계해야 한다.
5. **무인증 웹훅 (#6)**: 외부에서 누구나 /api/webhooks/make 로 작업 상태를 done 으로 바꾸고 result_url 을 임의 URL 로 주입할 수 있다. 쿠키 없는 요청이라 RLS 에서 막히는 부분도 있지만, 서비스 롤로 교체되는 순간 완전 개방된다. 공유 시크릿/HMAC 검증이 선행되어야 한다.
6. **refund 파손과 비원자적 과금 (#7, #8)**: 실패 시 환불이 실제로 잔액을 복구하지 못하고 거래 로그만 남아 잔액과 원장이 불일치한다. Supabase 쿼리 오류는 예외가 아니므로 runJobWithCredits 의 실패 경로가 대부분 타지 않는다. 차감/환불은 단일 DB 함수에서 update ... where credit_balance >= amount returning 형태로 원자화해야 한다.
7. **조직 미생성 (#9)**: 가입 후 org 와 org_members 를 만드는 트리거가 없어 신규 사용자는 어떤 기능도 쓸 수 없다. auth.users insert 트리거로 조직 생성 + super_admin 멤버 등록 + 무료 50 크레딧 원장 기록을 해야 한다.
8. **공개 랜딩 차단 (#10)**: 미들웨어가 /landing 으로 시작하는 모든 경로를 보호해 Track B 수익 경로(쿠팡 랜딩)가 외부 방문자에게 로그인 화면으로 보인다. 대시보드 관리 화면 경로를 /landing-pages 등으로 바꾸거나 /landing/ 하위를 예외 처리해야 한다.

4. 효율성 개선 제안

- 구조/아키텍처
  - 워커 런타임 분리: FFmpeg/yt-dlp/BullMQ 워커는 Vercel 서버리스에서 동작할 수 없다. `workers/` 별도 Node 엔트리(또는 Railway/Fly 컨테이너)로 분리하고, API 는 큐 투입만 담당하게 한다. 워커는 cookies 기반 클라이언트가 아닌 서비스 롤 전용 모듈(`lib/supabase/admin.ts`)을 사용한다.
  - 크레딧 원장 단일화: `credit_transactions` 를 진실의 원천으로 하고 잔액은 DB 함수(`consume_credits`/`grant_credits`)로만 변경. 클라이언트 테이블 쓰기 정책 제거.
  - `getOrgContext()` 헬퍼(인증 + org_id + 플랜 + 트랙 권한 검사)를 만들어 20여 곳의 중복 블록과 클라이언트 전달 orgId 를 제거하고, 플랜별 트랙 제한(free 는 Track A 만)을 서버에서 강제한다.
  - 폴더명을 `Nomad-Short-Factory` 로 정리하거나, 실제 의도가 블로그 스튜디오라면 PRD 를 새로 작성해야 한다.
- 성능
  - 롱폼 sections 를 jsonb 통째 갱신하지 말고 `longform_sections` 테이블로 정규화하거나 `jsonb_set` RPC 로 부분 갱신.
  - 대시보드 서버 컴포넌트의 순차 쿼리(org 조회 → 각 테이블)를 `Promise.all` 로 병렬화하고 `select('*')` 대신 필요한 컬럼만 조회.
  - 002 의 중복 인덱스 제거로 쓰기 비용 절감.
- 개발 생산성
  - `supabase gen types typescript` 로 DB 타입 생성 후 `createClient<Database>()` 적용, `any` 18건 제거.
  - 모든 API 입력을 zod 스키마로 검증(이미 의존성 존재). track/platform/url 등 문자열을 그대로 DB 에 넣는 현재 방식을 대체.
  - 색상 하드코딩 242회를 Tailwind 테마 토큰(globals.css `@theme`)으로 치환하고 미사용 테마 파일 2벌 정리.
  - 크레딧/결제/RLS 에 대한 최소 통합 테스트(vitest + supabase local) 추가.
- 운영/배포
  - `.env.example` 작성 후 코드가 실제 쓰는 키 이름으로 통일, 타 프로젝트 키 제거, 시작 시 zod 로 env 검증.
  - 노출 우려가 있는 실 키(OpenAI, Anthropic, OpenRouter, Supabase service)는 회전 권장.
  - YouTube 토큰 AES-256-GCM 암호화(이미 env 에 `CREDENTIALS_ENCRYPTION_KEY` 존재) 및 refresh 로직 추가.

5. 수정 작업 목록 및 권장 모델

#	작업	우선순위	예상 규모	권장 모델	선정 이유
1	RLS 재작성: `org_members` INSERT/UPDATE 를 서버 전용으로 제한, `organizations` 는 SELECT 만 허용(잔액/플랜 수정 금지), `credit_transactions` SELECT 만 허용, 001/002 중복 정책·인덱스 정리한 003 마이그레이션 작성	P0	M	Fable 5.1	테넌트 격리와 과금 데이터 보안, 실수 시 비용 최대
2	크레딧 RPC 재설계: `consume_credits` 를 `update ... where credit_balance >= p_amount returning` 원자화 + `auth.uid()` 소속 검사, `refund_credits`/`increment` 를 서비스 롤 전용 `grant_credits` 로 교체, anon/authenticated EXECUTE revoke, `credits.ts` 의 consume/refund/runJobWithCredits 를 오류 전파 방식으로 재작성	P0	M	Fable 5.1	돈과 직결된 원장 로직, 경쟁 조건 처리
3	결제 재설계: `payment_orders` 테이블에 주문(org, plan, amount, status) 선저장 → checkout 은 서버가 orgId 를 세션에서 결정 → confirm 에서 주문 조회, 금액 일치 검증, 멱등 처리 후 `grant_credits` 호출. Toss 웹훅 서명 검증 추가	P0	L	Fable 5.1	결제 보안/멱등성, 외부 PG 연동

#	작업	우선순위	예상 규모	권장 모델	선정 이유
4	auth.users insert 트리거로 조직(org_name 메타데이터 사용, slug 생성) + super_admin 멤버 + 초기 50 크레딧 원장 생성	P0	S	Opus 5.5	명확히 정의된 DB 트리거 구현
5	미들웨어 보호 경로 수정: 대시보드 랜딩 관리 경로를 분리하거나 /landing/ 공개 예외 처리, 보호 경로 배열화	P0	S	Sonnet 5.5	단순 경로 조건 수정
6	Make 웹훅에 공유 시크릿(HMAC) 검증 추가, 처리 시 서비스 롤 클라이언트 사용, jobId 존재/상태 전이 검증	P0	S	Opus 5.5	범위가 명확한 보안 보강
7	lib/server/org-context.ts 헬퍼 작성(인증, org_id, 플랜, 트랙 권한) 후 api 18개 라우트와 대시보드 페이지의 중복 org 조회 및 클라이언트 전달 orgId 제거, zod 입력 검증 적용	P1	M	Opus 5.5	다수 파일 기계적이지만 권한 판단 포함
8	YouTube OAuth: state 를 서명 쿠키 기반 nonce 로 변경, 토큰 AES-256-GCM 암호화 저장, refresh 토큰 갱신 유틸 작성	P1	M	Opus 5.5	API 연동 + 암호화, 범위 명확
9	워커 런타임 분리: workers/index.ts 엔트리 생성, 서비스 롤 lib/supabase/admin.ts 도입, jobs/sourcing/longform encode API 에서 add*Job 호출 연결, 워커 실패 시 grant_credits 환불	P1	L	Fable 5.1	배포 아키텍처 결정과 다중 모듈 연결
10	목업 제거: trends/longform score/storyline/storyboard/analytics 라우트를 lib/ai/openai-chat.ts, trends/scorer.ts, youtube-analytics.ts 실제 호출로 교체, 실패 시 예외 throw 로 환불 경로 연결	P1	M	Opus 5.5	API 연동 중간 규모
11	스키마 정합성 수정: youtube_uploads status 값 통일('scheduled' 추가 또는 코드 수정), jobs.track 과 encode 워커 Track D 분리, fal-image 오류 시 throw	P1	S	Opus 5.5	스키마와 코드 동시 수정 필요
12	yt-dlp/ffmpeg 인자에 -- 구분자 추가, URL 화이트리스트(douyin/xiaohongshu/youtube/tiktok 도메인) 검증	P1	S	Sonnet 5.5	단순하지만 명확한 보안 패치
13	env 정리: 코드 기준 .env.example 작성, 키 이름 통일(SUPABASE_SERVICE_ROLE_KEY 등), 타 프로젝트 키 제거, lib/env.ts zod 검증	P1	S	Sonnet 5.5	설정 파일 정리
14	Supabase 타입 생성 및 any 18건 제거, 롱폼 sections 부분 갱신 RPC 도입	P2	M	Opus 5.5	타입/데이터 접근 정리, 중간 규모
15	하드코딩 색상 242회를 Tailwind 테마 토큰으로 치환, 미사용 테마 파일 1벌로 통합, README/폴더명 정리	P2	M	Sonnet 5.5	반복적 스타일/문서 작업

6. 종합 평가

- 강점
  1. PRD/DESIGN/CLAUDE.md 가 상세하고 트랙별 파이프라인·크레딧 단가가 명확하게 정의되어 있다.
  2. 멀티테넌트 스키마(org 기반, RLS 활성화, 인덱스)와 크레딧 원장 개념이 초기부터 설계되어 있다.
  3. UI 가 12개 메뉴 대부분 구현되어 있고 TypeScript 컴파일 오류가 없으며, 외부 API 래퍼(FFmpeg는 execFile 사용 등)가 모듈화되어 있다.
- 약점
  1. RLS/RPC 설계 결함으로 타 조직 가입, 크레딧 무한 발행, 잔액 직접 수정이 가능하다.
  2. 결제 승인/환불/조직 생성이 모두 동작하지 않아 과금 SaaS 의 기본 흐름이 깨져 있다.
  3. 핵심 생산 파이프라인(큐, 워커, AI 호출)이 연결되지 않고 목업과 죽은 코드가 많다.
- 모델별 비율 (15개 작업 기준): Fable 5.1 약 27% (4개) / Opus 5.5 약 47% (7개) / Sonnet 5.5 약 27% (4개)
- 권장 진행 순서
  - 1단계 (보안/과금 차단, P0): 작업 1 → 2 → 3 → 4 → 5 → 6. 이 단계 완료 전에는 외부 공개 금지.

  - 2단계 (기능 연결, P1): 작업 7 → 13 → 9 → 11 → 10 → 8 → 12. 공통 헬퍼와 env 정리 후 워커를 붙이고 목업을 실제 호출로 교체.
  - 3단계 (품질, P2): 작업 14 → 15. 타입 안정성, 디자인 토큰, 문서 정리.
- 주 담당 모델: **Opus 5.5**. 남은 작업량의 대부분은 PRD 에 이미 명확히 정의된 파이프라인을 API 와 워커에 연결하는 중간 규모 구현(헬퍼 도입, 외부 API 연동, 목업 교체, 스키마 정합성)이라 Opus 5.5 가 비용 대비 가장 적합하다. 다만 1단계의 RLS·크레딧 RPC·결제 재설계와 워커 런타임 분리는 실수 시 금전 손실과 테넌트 데이터 유출로 직결되므로 반드시 Fable 5.1 이 먼저 처리하고, 그 결과물(원장 함수, org-context 규약) 위에서 Opus 5.5 가 나머지를 이어받는 구성을 권장한다.